



CERT-IN EMPANELLED
GOVT OF INDIA • MEITY

BOARD BRIEFING • CYBER RESILIENCE 2026

The 2026 Cyber Resilience Guide for Indian Boards

A board-level playbook for cyber-risk oversight under India's tightening regulatory regime — CERT-In, RBI, SEBI and the DPDP Act. Inside: a compliance checklist, the anatomy of a regulator-format audit report, and a 12-month resilience roadmap.

DOCUMENT

MKS-BOARD-GUIDE-2026

VERSION

2026.1

ISSUED

8 June 2026

CLASSIFICATION

Public • Board Briefing



www.macksofy.com
Website



services@macksofy.com
Enquiries



+91 99308 24239
Direct line

1. Why 2026 is different

Cyber risk has crossed the line from an IT problem to a board problem. In India that shift is now written into regulation. The CERT-In Directions compress incident reporting to six hours. The RBI and SEBI frameworks make the board — not just the CISO — accountable for a tested security programme. The DPDP Act puts personal-data breaches under a statutory regulator that can levy penalties of up to ₹250 crore. For a director, cyber risk can no longer be delegated downward and forgotten. This guide is written for that director, and assumes no technical background. It sets out the questions to ask, the controls to insist on, a 12-month roadmap to get there, and a clear picture of what good looks like — an independent, regulator-format audit.

2. The board's cyber-resilience mandate

Resilience is broader than security. Security tries to stop the breach; resilience assumes one will happen and asks how quickly the business recovers. Three responsibilities sit with the board and cannot be delegated away:

Oversight. Ensure a named owner, a board-approved policy, and a reporting cadence that surfaces real risk — not a green dashboard.

Assurance. Insist on independent testing. A self-assessment is not assurance; an external audit and VAPT are.

Readiness. Confirm the organisation can detect, report within the legal window, and recover — and that this has been rehearsed, not just documented.

3. India’s regulatory stack at a glance

Regime	Who it applies to	Headline obligation
CERT-In Directions (Apr 2022)	Every body corporate, intermediary, data centre & VPS provider	Report 20 classes of cyber incident within 6 hours; keep 180-day logs in India; maintain synchronised time.
RBI Cyber Security Framework	Banks, NBFCs, co-operative banks, payment operators	Board-approved cyber-security policy, CISO, SOC, IT-governance & a Cyber-Crisis Management Plan (CCMP).
SEBI CSCRF (2024)	Stock brokers, AMCs, depositories, market infrastructure institutions	Graded controls by entity size, VAPT, SOC/market-SOC onboarding, and periodic audit submission.
DPDP Act 2023	Any organisation processing digital personal data of individuals in India	Consent-based processing, breach notification to the Data Protection Board, and Significant-Data-Fiduciary duties.
IT Act s.70 / NCIIPC	Operators of declared Critical Information Infrastructure (CII)	Mandatory NCIIPC-aligned controls and audits for protected systems (power, banking, telecom, transport).
ISO/IEC 27001:2022	Voluntary — the de-facto baseline expected by enterprise buyers	Certified ISMS; increasingly a contractual pre-condition for BFSI, SaaS and government tenders.

4. The 2026 board cyber-resilience checklist

Walk this with your CISO. Every box that cannot be ticked with evidence is an open question for the board, not the IT team.

Governance & accountability

- ☐ A board-approved information-security / cyber-security policy exists and was reviewed in the last 12 months.
- ☐ A named CISO (or equivalent) reports cyber risk to the board or a board committee at least quarterly.
- ☐ Cyber risk appears on the enterprise risk register with a defined owner, appetite statement and treatment plan.
- ☐ Roles and decision rights are defined in a Cyber-Crisis Management Plan that the board has seen.
- ☐ Directors-and-officers (D&O) cover and a standalone cyber-insurance policy have been reviewed against current exposure.

RBI / banking controls (if regulated)

- ☐ The bank is mapped to the correct RBI tier and the corresponding baseline controls are evidenced.
- ☐ A 24x7 Security Operations Centre is operational, in-house or via an accountable MSSP, with defined SLAs.
- ☐ Critical and high-severity vulnerabilities from the last VAPT are closed or have board-noted compensating controls.
- ☐ The IT Governance, IT Outsourcing and Digital-Lending controls are evidenced where applicable.

SEBI / market controls (if regulated)

- ☐ The entity is classified under the CSCRf (Self / Mid / Small / Qualified) and the graded controls are met.
- ☐ Annual VAPT and periodic cyber-audit reports are filed with the relevant MII / exchange on schedule.
- ☐ Market-SOC / SOC onboarding is complete and log feeds are confirmed flowing.

Incident readiness (CERT-In)

- ☐ A documented 6-hour CERT-In incident-reporting runbook names the responsible person and the back-up.
- ☐ Logs are retained for 180 days within India and time is synchronised to NIC / NPL sources.
- ☐ The incident-response plan was exercised (tabletop or live) in the last 12 months with board visibility of the outcome.
- ☐ An external DFIR retainer is in place so forensic help is hours, not days, away.

Data protection (DPDP Act)

- ☐ A data inventory and processing record identify where personal data lives and who it is shared with.
- ☐ Consent, grievance-redressal and breach-notification mechanisms are implemented and tested.
- ☐ If the organisation is (or may be notified as) a Significant Data Fiduciary, the extra duties (DPO, DPIA, audit) are scoped.

5. What a regulator-format audit report should contain

When you commission an independent audit, this is the structure to expect. If a report skips the control-attestation table or the re-test, it is a scan, not an audit. Macksofy delivers full sample reports in this format at macksofy.com/sample-reports.

1. Auditor & empanelment	Identifies the CERT-In empanelled auditor, lead-auditor credentials and a digitally-signed attestation — the page a regulator checks first.
2. Auditee & scope	The systems, locations, IP ranges and applications in scope, plus what was explicitly excluded and why.
3. Methodology & standards	The frameworks applied (CERT-In baseline, OWASP, PTES, ISO 27001 Annex A) and the test windows.
4. Executive summary	A one-page, board-readable verdict: overall posture, count of findings by severity, and the headline risks.
5. Findings register	Each finding with a severity (Critical / High / Medium / Low), CVSS score, business impact, evidence and a remediation owner.
6. Control-attestation table	A line-by-line statement of whether each required control is Implemented / Partial / Not-implemented — the regulator-format core.
7. Remediation & re-test	Agreed fix dates and the result of the re-test, so the report closes the loop rather than just listing problems.
8. Compliance statement	The formal auditor declaration in the regulator's submission format (CERT-In / RBI / SEBI / UIDAI as applicable).

6. The 12-month cyber-resilience roadmap

A realistic sequence for an organisation starting from a typical mid-market baseline. Each quarter builds on the last: see, fix, prove, sustain.

Quarter 1 — See clearly

ESTABLISH THE BASELINE

- Asset & data inventory; classify crown-jewel systems and personal-data stores.
- Gap assessment against the applicable regulator framework (RBI / SEBI / CERT-In / DPDP).
- Board-approved cyber-security policy refreshed; CISO accountability confirmed.
- Stand up or contract a 24×7 SOC; confirm 180-day log retention in India.

Quarter 2 — Close the gaps

REMEDiate THE CRITICALS

- Full-scope VAPT of internet-facing and crown-jewel systems; fix all Critical / High findings.
- Roll out MFA everywhere, privileged-access management and email-security hardening.
- Encrypt data at rest and in transit; tighten backup isolation against ransomware.
- Publish the CERT-In 6-hour reporting runbook and assign named owners.

Quarter 3 — Prove it works

TEST UNDER PRESSURE

- Red-team / breach-and-attack simulation against the agreed crown jewels.
- Tabletop a ransomware and a data-breach scenario with the board and executives.
- Third-party / supply-chain risk review of the top vendors with data access.
- DPDP readiness: consent, grievance and breach-notification flows tested end to end.

Quarter 4 — Make it durable

CERTIFY & SUSTAIN

- Independent audit in the regulator's format; file the submission package.
- Pursue or renew ISO 27001 certification as the enterprise baseline.
- Agree the next-year cyber budget and KRI targets with the board.
- Lock a DFIR retainer and a quarterly board cyber-risk reporting cadence.

7. Fifteen questions every board should ask its CISO

- What are our five crown-jewel systems, and when were they last independently tested?
- If we were breached tonight, who declares the incident, and can we report to CERT-In within 6 hours?
- Which regulator obligations (RBI / SEBI / CERT-In / DPDP) apply to us, and where are we non-compliant today?
- How many Critical and High vulnerabilities are currently open, and what is the oldest one?
- When did we last restore from backup in a test — not in theory — and how long did it take?
- Do we have a DFIR retainer, and how quickly can forensic responders be engaged?
- What personal data do we hold, where does it live, and who outside the company can access it?
- How much cyber and D&O insurance do we carry, and what does it explicitly exclude?
- Which third parties could take us down or leak our data, and how are they assured?
- What is our mean time to detect and mean time to respond, and how do they trend?
- Has the incident-response plan been exercised with this board in the room?
- What single investment would most reduce our cyber risk next quarter?
- Are privileged accounts protected with MFA and just-in-time access?
- What would a ransomware event cost us per day of downtime?
- Who owns cyber risk on this board, and is the reporting cadence good enough?

8. The first 72 hours of a major incident

When an incident hits, the board does not run the response — but it must know the response runs. This is the clock your organisation should be able to keep without improvising on the night.

Hour 0-6	Activate the Cyber-Crisis Management Plan. Contain. Preserve evidence. File the CERT-In report inside the 6-hour window. Engage the DFIR retainer.
Hour 6-24	Confirm scope and whether personal data was affected (DPDP). Brief the board chair and legal counsel. Decide on regulator and customer communications.
Hour 24-72	Stand up clean recovery from isolated backups. Issue required notifications (Data Protection Board, RBI / SEBI as applicable). Prepare the board-level situation report.
After 72 hours	Root-cause analysis, remediation plan with dates, and a lessons-learned review the board signs off — feeding back into the roadmap.

9. Resilience metrics the board should track

Metric	What it tells the board
Mean time to detect (MTTD)	How long an intruder is in before you notice. Trend down.
Mean time to respond (MTTR)	Detection to containment. The number that bounds the damage.
Open Critical / High findings	Count and age of the worst unfixed issues. Aim for zero aged Criticals.
Patch / remediation SLA hit-rate	Percentage of fixes closed within the agreed window.
Phishing-simulation failure rate	A proxy for human-layer resilience. Trend down with training.
Backup restore-test success	Did the last real restore work, and how fast? Resilience, not just security.
Third-party assurance coverage	Percentage of high-risk vendors with current assurance.

10. How Macksofy helps

Macksofy Technologies is a CERT-In empanelled information-security auditor and consulting firm. We take boards from gap assessment to regulator-ready in a single accountable engagement: VAPT and red teaming, RBI / SEBI / CERT-In / DPDP audits, 24×7 managed SOC, DFIR retainers and ISO 27001 readiness — delivered for BFSI, fintech and government clients across India and the GCC.

To turn this guide into a costed plan for your organisation, book a fixed-scope consultation at macksofy.com/contact or write to info@macksofy.com. We reply within one business day.

This guide is general information, not legal or compliance advice. Confirm your specific obligations with a qualified adviser and the current text of each regulation.



**Macksofy
Technologies Pvt
Ltd**
308, Building 11,
SRA Commercial
Tower, BKC,
Mumbai 400051

DOCUMENT 2026.1
Issued 8 June 2026

Public • Board Briefing
© Macksofy Technologies — all rights
reserved